Audit de securite - Plateforme Code un max

1. Reconnaissance

1.1 Vérifier que la cible est joignable

```
docker exec attaquant ping -c 2 10.40.0.10
```

1.2 Installer les outils (nmap et tshark)

```
docker exec attaquant bash -c "apt-get update && apt-get install -y nmap"
docker exec attaquant bash -c "DEBIAN_FRONTEND=noninteractive apt-get
install -y tshark"
```

1.3 Cartographier les services exposés

Objectif : Scanner l'ensemble des ports pour identifier les version des ports exposés

```
docker exec attaquant nmap -p- 10.40.0.10
```

l'option `-p-` permet de scanner l'ensemble de tous les ports plutôt que les 1000 ports les plus utilisés.

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant nmap -p- 10.40.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-10-27 12:38 UTC
Nmap scan report for dvwa-cible.cybersec-audit-codemax_cyberlab-net (10.40.0.10)
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE
80/tcp open  http
MAC Address: 56:C9:C2:50:65:D3 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.48 seconds
brandon@debian:~/cybersec-audit-codemax$
```

```
docker exec attaquant nmap -sV -p 80 10.40.0.10
```

- l'option `-sV` permet de détecter les services ainsi que leur version.
- l'option `-p` permet de spécifier un port en particulier, ici le port 80 (HTTP)

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant nmap -sV -p 80 10.40.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-10-27 12:39 UTC
Nmap scan report for dvwa-cible.cybersec-audit-codemax_cyberlab-net (10.40.0.10)
Host is up (0.000042s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.25 ((Debian))
MAC Address: 56:C9:C2:50:65:D3 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.29 seconds
brandon@debian:~/cybersec-audit-codemax$
```

1.4 Fingerprinting de l'application web

Objectif : Collecter les en-têtes HTTP pour identifier PHP, les cookies de sessions et la redirection vers `login.php`

```
docker exec attaquant curl -s -I http://10.40.0.10/
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -I http://10.40.0.10/
HTTP/1.1 302 Found
Date: Tue, 27 Oct 2026 12:39:57 GMT
Server: Apache/2.4.25 (Debian)
Set-Cookie: PHPSESSID=dubhgigofceb2363vkf3ijndr3; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=dubhgigofceb2363vkf3ijndr3; path=/
Set-Cookie: security=low
Location: login.php
Content-Type: text/html; charset=UTF-8
```

```
docker exec attaquant curl -s -I http://10.40.0.10/login.php
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -I http://10.40.0.10/login.php
HTTP/1.1 200 OK
Date: Tue, 27 Oct 2026 12:41:05 GMT
Server: Apache/2.4.25 (Debian)
Set-Cookie: PHPSESSID=3rlotcqvidob94j3qvonesmju5; path=/
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=3rlotcqvidob94j3qvonesmju5; path=/
Set-Cookie: security=low
Content-Type: text/html;charset=utf-8
```

1.5 Capture et analyse du traffic HTTP

Objectif : Enregistrer et analyser le traffic HTTP échangé dans un fichier `.pcap` pour relire la capture du traffic

```
docker exec attaquant bash -c "(sleep 2; for i in 1 2 3 4 5 6; do curl -s -
o /dev/null http://10.40.0.10/; done) & tshark -i eth0 -f 'host 10.40.0.10
```

```
and port 80' -c 10 -a duration:20 -w /tmp/capture-recon.pcap && cp
/tmp/capture-recon.pcap /data/"
```

```
docker exec attaquant tshark -r /data/capture-recon.pcap -Y http
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant tshark -r /data/capture-recon.pcap -Y http
Running as user "root" and group "root". This could be dangerous.
    4 0.000054516   10.40.0.20 → 10.40.0.10   HTTP 140 GET / HTTP/1.1
    6 0.000490190   10.40.0.10 → 10.40.0.20   HTTP 489 HTTP/1.1 302 Found
brandon@debian:~/cybersec-audit-codemax$
```

1.5.1 Analyse avec Wireshark

```
docker exec attaquant bash -c "(sleep 2; for i in 1 2 3 4 5 6; do curl -s -
o /dev/null -d 'username=admin&password=password'
http://10.40.0.10/login.php; done) & tshark -i eth0 -f 'host 10.40.0.10 and
port 80' -c 10 -a duration:20 -w /tmp/capture-recon.pcap && cp
/tmp/capture-recon.pcap /data/"
```

Filtre wireshark : `ip.src==10.40.0.20&&http`

No.	Time	Source	Destination	Protocol	Length	Info
→ 4	0.000117456	10.40.0.20	10.40.0.10	HTTP	251	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)

```
54 79 70 65 3a 20 61 70  70 6c 69 63 61 74 69 6f   Type: ap plicatio
6e 2f 78 2d 77 77 77 2d  66 6f 72 6d 2d 75 72 6c   n/x-www- form-url
65 6e 63 6f 64 65 64 0d  0a 0d 0a 75 73 65 72 6e   encoded· ···usern
61 6d 65 3d 61 64 6d 69  6e 26 70 61 73 73 77 6f   ame=admi n&passwo
72 64 3d 70 61 73 73 77  6f 72 64                  rd=passw ord
```

1.6 Interception et manipulation de requêtes

Installation de l'outil BurpSuite

```
docker exec attaquant bash -c "apt-get install -y default-jre && curl -o
/tmp/burp.sh 'https://portswigger.net/burp/releases/download?
product=community&type=Linux' && chmod +x /tmp/burp.sh"
```

Forger une requête personnalisée avec `curl`

```
docker exec attaquant curl -s -v -H "User-Agent: AuditCodeMax"
http://10.40.0.10/login.php -o /dev/null
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -v -H "User-Agent: AuditCodeMax" http://10.40.0
.10/login.php -o /dev/null
*   Trying 10.40.0.10:80...
* Connected to 10.40.0.10 (10.40.0.10) port 80 (#0)
> GET /login.php HTTP/1.1
> Host: 10.40.0.10
> Accept: */*
> User-Agent: AuditCodeMax
>
< HTTP/1.1 200 OK
< Date: Tue, 27 Oct 2026 12:45:25 GMT
< Server: Apache/2.4.25 (Debian)
< Set-Cookie: PHPSESSID=j2lufo56ts1ftav2vbpaqv1as5; path=/
< Expires: Tue, 23 Jun 2009 12:00:00 GMT
< Cache-Control: no-cache, must-revalidate
< Pragma: no-cache
< Set-Cookie: PHPSESSID=j2lufo56ts1ftav2vbpaqv1as5; path=/
< Set-Cookie: security=low
< Vary: Accept-Encoding
< Content-Length: 1523
< Content-Type: text/html;charset=utf-8
<
{ [1523 bytes data]
* Connection #0 to host 10.40.0.10 left intact
brandon@debian:~/cybersec-audit-codemax$
```

1.7 Résultat de la reconnaissance

- Cible : `dvwa-cible` / IP : `10.40.0.10`
- Service exposé : `Apache httpd 2.4.25` / port : `80`
- Application : PHP (`PHPSESSID`) - **PHPSESSID** est un identifiant unique (sous forme de chaîne de caractères obligatoire aléatoire) généré par PHP pour suivre la session d'un visiteur sur l'application web

1.7.1 Liste des CVE pour Apache 2.4.25 (DVWA)

Identifiant CVE	Sévérité (CVSS)	Type de vulnérabilité	Description & Impact
CVE-2019-0211	🔴 **7.2 Élevée**	Élévation de privilèges	Une exécution de code local via un processus enfant (ex: via PHP) permet d'obtenir les privilèges root sur le processus parent.
CVE-2017-7668	🟠 **7.5 Moyenne**	Déni de service (DoS)	Des en-têtes HTTP malformés déclenchent une lecture hors limites dans `ap_find_token()`, provoquant le plantage du serveur.
CVE-2017-3167	🟠 **7.5 Moyenne**	Contournement d'authentification	Les modules tiers utilisant `ap_get_basic_auth_pw()` peuvent contourner les exigences d'authentification.
CVE-2017-3169	🟠 **7.5 Moyenne**	Déréférencement de pointeur NULL	Des modules tiers peuvent déclencher un déréférencement de pointeur NULL dans `mod_ssl`, entraînant un plantage.
CVE-2017-7679	🟡 **5.3 Moyenne**	Divulgation d'informations	Une entrée malveillante dans `mod_mime` peut divulguer des données sensibles de la mémoire de pile ou causer un plantage.

1.7.2 Fiabilité du Fingerprinting (curl vs nmap)

- **curl** récupère l'en-tête HTTP explicite (`Server`), qui peut être facilement modifié, masqué ou falsifié par l'administration du serveur.
- **nmap -sV** analyse le comportement réseau et les réponses aux sondes, offrant une détection de version plus robuste, bien qu'elle puisse être influencée par le rétroportage (*backport*) de correctifs de sécurité par la distribution.

1.7.3 Le rétroportage (Backporting)

Le rétroportage consiste, pour les mainteneurs d'une distribution comme Debian, à appliquer un correctif de sécurité récent sur une ancienne version d'un logiciel, sans modifier son numéro de version officiel.

Impact sur l'audit : Un scanner de vulnérabilités ou un outil comme `nmap` peut signaler à tort qu'une machine est vulnérable (faux positif) en se fiant uniquement au numéro de version, alors que le correctif a en réalité déjà été appliqué par la distribution.